

CHAPTER 5

CONCLUSION

5.1 Introduction

The current project is about an important problem of healthcare information security, which has been widely acknowledged by researchers before – the lack of affordable and security-oriented infrastructure for small private healthcare institutions. The case study chosen to motivate the current research illustrates the problem in question, which is common to all small healthcare facilities, because of the limited budget and reactive attitude toward information security issues.

The goal of this project is to develop and implement the Secure Cloud-based Patient Data Management System for Alamin Clinic using the three-tier architecture approach in Amazon Web Services that would use Infrastructure as Code and DevSecOps pipelines to allow for automated, reproducible, and security validated deployments. The goal is aided by three specific objectives, which include: (a) investigating the fundamental technologies and security principles behind the development of the proposed system; (b) developing the architecture, database structure, and user interface for the system; and (c) evaluating the system after its deployment via testing.

The importance of the project is evident in three areas. Firstly, the system tackles the problems which led to five days of downtime and data loss for patients at Alamin Clinic. Secondly, it proves that infrastructure as code and DevSecOps automation can make advanced enterprise security practices applicable to healthcare organizations which lack resources. Lastly, academically, it presents a case study evaluation of cloud security practices using HIPAA compliance as a metric.

5.2 Achievements

5.2.1 Findings from Literature Review

The literature review performed in Chapter 2 reveals three facts that support the design of the proposed solution directly.

First, security shortcomings discovered at Alamin Clinic are typical for small healthcare providers. According to (Argaw *et al.*, 2019), cyberattacks against hospitals use the same security gaps as those present at Alamin Clinic: the presence of old equipment, lack of network segmentation, and insufficient patching processes. Hence, the security issues faced by Alamin Clinic are not exceptional but representative of a common problem.

Second, no currently existing solutions fill the existing gap. The comparison between current solutions performed in Chapter 2 shows that neither traditional on-premise solutions nor open source solutions, such as OpenEMR, can take care of the clinic's security needs, as both types of solutions shift all the responsibility for securing operations from the cloud to the organization's IT specialists. Commercial solutions, like Epic Systems, offer comprehensive security features but cannot be afforded by small and private clinics due to their high price and excessive complexity. There are no currently existing affordable off-the-shelf solutions with security automation features.

Third, the chosen technical solution is supported by scientific researches. In particular, Paidy and Chaganti (2024) prove that IaC greatly decreases the amount of configuration drifts and helps in quick and efficient recovery from infrastructure incidents. Also, Al-Issa *et al.* (2019) state that access to confidential information, integrity attacks, and availability attacks, these three threats that the proposed solution is aimed at are the most prevalent ones in healthcare cloud solutions.

5.2.2 Status of Project Objectives

Objective (a): Explore underlying principles: This objective has been fully accomplished. Chapter 2 performs an exhaustive review of the relevant academic and industrial literature relating to the suggested system in seven fields: cloud computing in the context of healthcare; three-tier architecture; AWS shared responsibility model;

Infrastructure as Code using Terraform; DevSecOps; shift-left security; and Identity and Access Management using Role-Based Access Control (RBAC). It validates the appropriateness of every selected technology and establishes the academic background for the design choices presented in Chapter 4.

Objective (b): System Design. The design process in relation to the above objective has been fully completed in PSM1. Chapter 4 provides the complete design for the above objective, which includes the following: three-tier VPC network design having six subnets in two different Availability Zones; design of Security Groups and Network ACLs in two separate network layers; IAM roles and Least Privilege Policy design; six-staged DevSecOps CI/CD pipeline with blocking automation on critical issues; PostgreSQL database design with six tables having Row Level Security policy; and finally the interface wireframes for the three user roles. The development process is scheduled for PSM2 Sprints 2 to 4.

Objective (c) System Testing: The objective has been partially achieved from the perspective of design. The testing strategy has been established in terms of including operational testing consisting of vulnerability scans (using Trivy, SonarQube, and Checkov), an RTO stress test that involves the case of wiping and redeployment due to ransomware attack, and assessment of HIPAA compliance posture using AWS Security Hub. The user acceptance testing would consist of not less than three users being tested, wherein each of them will represent one of the user roles.

5.3 Suggested Plan for Project Implementation and Execution

PSM2 stage of the project will proceed in four sprints, as per the Agile with DevSecOps approach discussed in Chapter 3. The sprints would be based on the design specifications of Chapter 4, and each sprint would be limited by a security gate before moving ahead to the next sprint.

Sprint 2: Network Infrastructure and Database Layer The first sprint for implementing this architecture will configure the AWS VPC with Terraform, which will set up the full three-tier network infrastructure including the public subnets that will have the Application Load Balancer and the NAT Gateway running on them, the

private application subnets where the EC2 instances will be located and the isolated database subnets for the RDS PostgreSQL instance. The Security Groups and Network ACLs will be configured according to Chapter 4, Sections 4.3.2 and 4.3.3. The RDS instance will be launched with data encryption using KMS and backups being automatically generated. This sprint will finish when Checkov detects no critical misconfiguration in the Terraform files and the RDS instance cannot be reached from the public internet.

Sprint 3: Application Layer and Authentication The second implementation sprint will launch the Docker containerised application stack containing a React frontend and a Node.js/Express backend onto the EC2 instances running in the private application subnet. The JWT-based RBAC authentication system will be developed with three roles being defined – Doctor, Admin and Patient – according to Chapter 4, Section 4.3.5. The PostgreSQL row-level security policies will be added to the `medical_records` and `patients` tables according to Chapter 4, Section 4.4.3. The Application Load Balancer will be configured to perform the HTTPS termination with the ACM-provided TLS certificate. The sprint will end once Trivy detects no critical CVEs in the container images and all three roles are tested.

Sprint 4: DevSecOps Pipeline & Monitoring Third Implementation Sprint will involve setting up and configuring GitHub Actions CI/CD pipeline with Trivy, SonarQube, and Checkov as automated blocking stages, as specified in Chapter 4, Section 4.3.6. Amazon CloudWatch will be configured using log groups, metric alarms, and alerting thresholds for anomalous authentication patterns. AWS CloudTrail will be configured for full API audit logging. The sprint will be concluded once the pipeline is able to block test commit which intentionally contains a critical vulnerability and AWS CloudTrail will be confirmed to log any accesses to patients' data.

Sprint 5: Security Assessment & HIPPA Compliance Testing

Final Implementation Sprint will conduct full security assessment procedure. Scan reports obtained from automated scans performed with Trivy, SonarQube, and

Checkov will be reviewed. Recovery Time Objective stress test will involve simulating total infrastructure wipeout followed by re-deploying using Terraform and measuring recovery time in terms of time required for redeployment, compared to NFR-06 which requires recovery time not longer than 15 minutes. HIPPA compliance will be assessed using AWS Security Hub. User Acceptance Testing will be conducted using three representative participants from Doctor, Admin, and Patient roles. Results of this sprint will form the main part of Chapter 5 (Implementation and Testing) of the PSM2 report.

Deliverables of PSM2 will conclude the objectives of this project and include the final report with Chapters 5 and 6, appendices, and fully deployed application running on AWS.